

Task 1 – Cybersecurity Fundamentals & Practical Awareness Report

- **Intern Name:** Balireddy Chandramouli Reddy
- **Role / Position:** Cybersecurity Analyst Intern
- **Email Address:** (channdramoulireddy56@gmail.com)
- **Date of Submission:** (25)

Submission & Link Details

- **GitHub Repository Link:** <https://github.com/your-username/NovaShyld> Task 1

Understanding CIA Triad

The CIA Triad is a fundamental framework in information security used to protect data and maintain secure, reliable systems. It guides policies to ensure information remains confidential, accurate and accessible to authorized users.

Components of the CIA Triad



Confidentiality

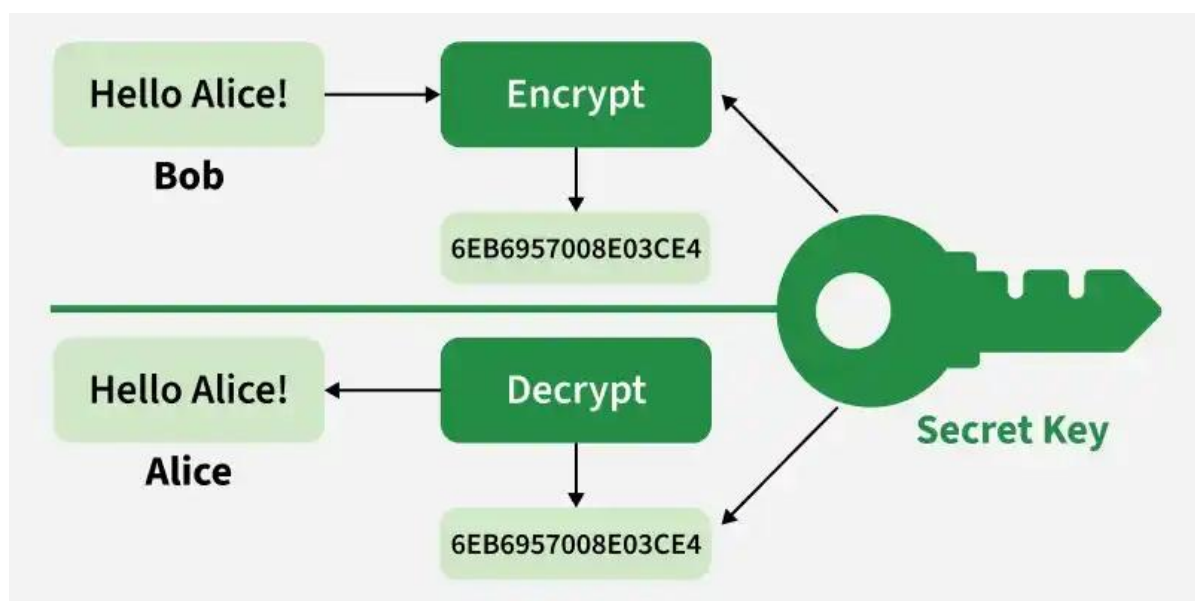
Confidentiality ensures that sensitive data is accessible only to authorized individuals or systems. Its purpose is to prevent unauthorized viewing, access or misuse of private information.

Risks to Confidentiality

- **Unauthorized Access:** Attackers exploit vulnerabilities to access protected data.
- **Weak Encryption:** Outdated or weak encryption can be easily broken, exposing sensitive information.
- **Insider Threats:** Employees or trusted users may leak or accidentally expose confidential data.

Ensure Confidentiality

- **Encryption:** Use strong encryption methods like [AES](#) or [RSA](#) to protect data from unauthorized reading. Avoid outdated algorithms like [DES](#).
- **VPN:** A Virtual Private Network creates an encrypted tunnel for internet communication, preventing interception
- **Access Controls:** Implement strict authentication and authorization policies to limit data access to only authorized users.



Confidentiality

Integrity

Integrity ensures that data remains accurate, authentic and unaltered during storage or transmission. Any unauthorized modification or corruption compromises the reliability of data.

Risks to Integrity

- **Data Tampering:** Attackers may intentionally alter or corrupt data for malicious purposes.
- **Malware & Ransomware:** Malicious software can modify, encrypt or destroy data, leading to loss and system disruption.

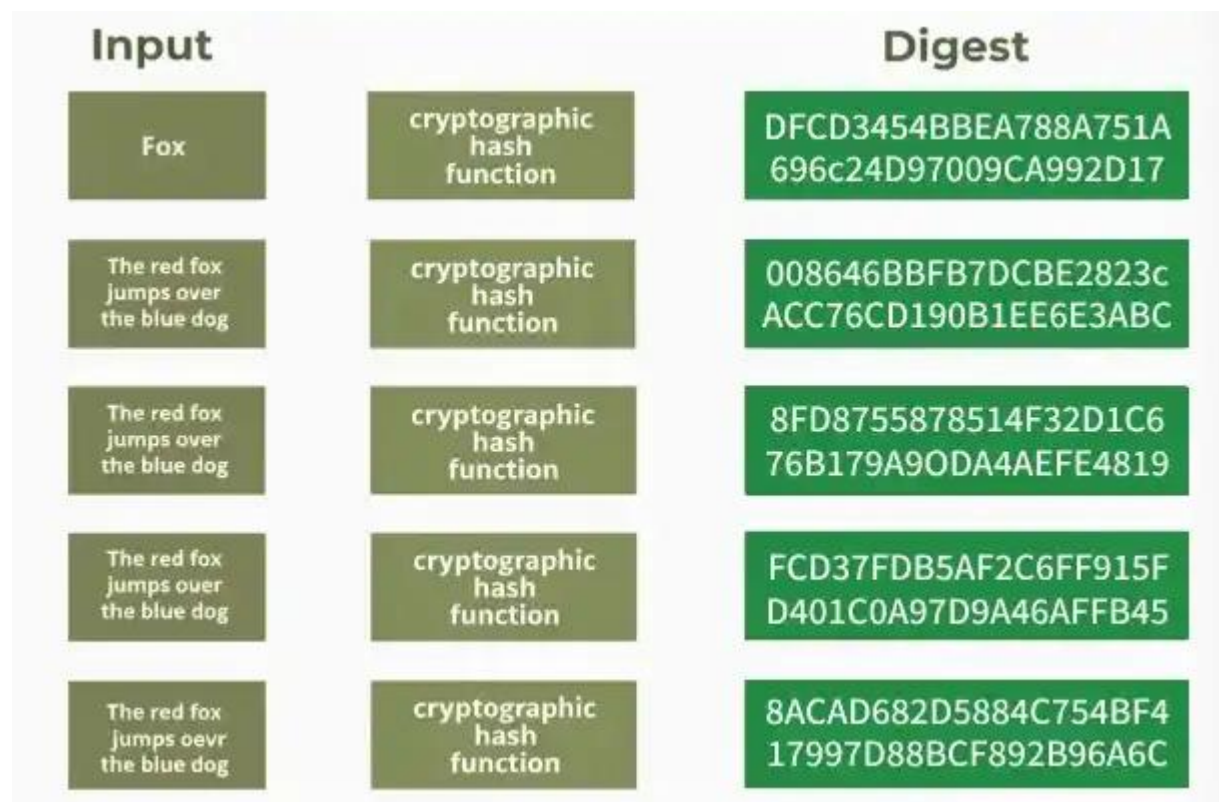
Ensure Integrity

[Hash Functions](#) detects modifications by generating unique hash values for data. Common hash functions include

- **MD5:** Produces a 128-bit hash value.
- **SHA Family:** Includes SHA-1, SHA-2, SHA-3 with varying bit lengths.

Working of Hash Functions

- **Host A Sends Data:** Host A creates a hash value (H1) using a hash function.
- **Attach Hash:** H1 is sent along with the data.
- **Host B Verifies:** Host B generates a new hash (H2) from the received data.
- **Compare:** If $H1 = H2$, the data is unchanged (integrity preserved) else $H1 \neq H2$, the data was altered or corrupted.



Hash Function

Note: Even a small change in the input (like altering a single word or character) will completely change the resulting hash.

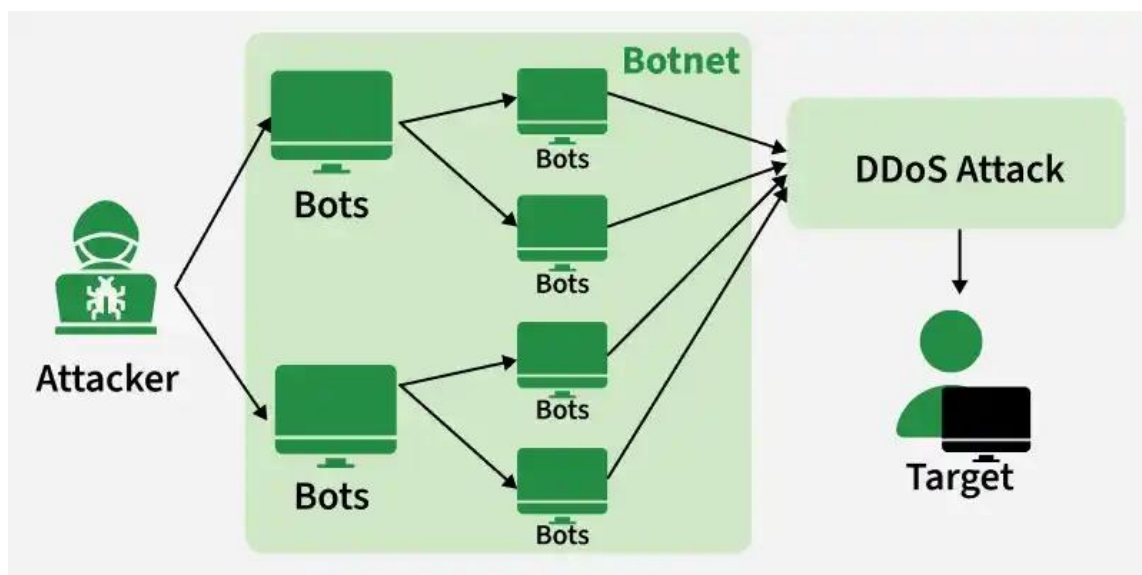
Availability

Availability ensures that systems, networks and data are accessible to authorized users whenever needed. Disruptions can halt operations and cause major losses.

Risks to Availability

- **DoS and DDoS Attacks:** [Denial of Service \(DoS\)](#) or [Distributed Denial of Service \(DDoS\)](#) attacks flood network resources with excessive traffic, making them unavailable to legitimate users.
- **Impact:** Such attacks can cause major service disruptions, downtime and financial losses for companies.

Ensure Availability



To ensure availability, network administrators should focus on the following factors:

- **Hardware Maintenance:** Regularly maintain and upgrade hardware to prevent failures and ensure smooth operations.
- **Regular Upgrades:** Keep systems and software updated to maintain performance and security.
- **Failover Plan:** Implement failover systems so that if one component fails, another can take over, minimizing downtime.

- **Preventing Bottlenecks:** Monitor and manage network traffic to avoid congestion or bottlenecks, ensuring consistent performance.

A Few Examples of the CIA Triad

These real incidents show how gaps in confidentiality, integrity, or availability led directly to major consequences and why architecting your controls around the triad still matters.

Confidentiality breach

A healthcare staffing platform, ESHYFT, exposed over [86,000 records](#), complete with social security numbers, professional credentials, and scanned IDs, in a publicly accessible Amazon S3 bucket for months. There was no encryption or access control, and security researchers disclosed the exposure before the firm secured its cloud assets.

Integrity violation

Financial systems often pause file integrity checks during maintenance windows. One [organization](#) discovered that attackers had retroactively edited transaction logs on a billing system to hide fraudulent transfers. With integrity monitoring disabled during a patch cycle, the manipulation went undetected until discrepancies surfaced during reconciliation.

Availability failure

In London, hospitals served by [Synnovis](#), a diagnostic laboratory for major NHS trusts, experienced significant disruptions after a ransomware attack shut down their IT systems. Over 1,500 surgical procedures and outpatient services were postponed. Systems remained offline for days, and clinical capacity dropped sharply.

These cases illustrate that data exposure, undetected tampering, or service unavailability is rarely accidental; it is the result of a missing or broken CIA control. When teams cannot point clearly to a failed leg of the triad, the response becomes slower, more expensive, and less effective.

In practice, designing around CIA does more than meet compliance; it helps prevent failures by making sure:

- Confidentiality controls limit access and prevent public exposure
- Integrity checks are continuous, not skipped during updates
- Availability systems are exercise-tested, not assumed reliable

Mapping critical workflows: cloud storage, billing systems, and lab processing, to each pillar ensures that when something breaks, your team knows exactly what went wrong and where to fix it.

Overview of the MITRE ATT&CK Framework

MITRE ATT&CK is a comprehensive knowledge base used to understand, classify, and analyze adversary behaviors in the cybersecurity domain. The acronym stands for Adversarial Tactics, Techniques, and Common Knowledge, and this framework details the tactics and techniques employed by attackers. Consequently, security teams can better recognize threats, enhance defense strategies, and effectively address vulnerabilities.

The **MITRE ATT&CK** framework provides a common language and reference point for cybersecurity professionals, making threat intelligence more meaningful and actionable. Continuously updated based on observations from real-world attacks, it becomes an indispensable tool for organizations aiming to adopt a proactive approach against cyber threats.

Key Components of the MITRE ATT&CK Framework

- **Tactics:** High-level strategies used by adversaries to achieve their goals (e.g., initial access, privilege escalation).
- **Techniques:** Specific methods employed to execute tactics (e.g., phishing, password cracking).
- **Procedures:** Detailed explanations of how adversaries apply specific techniques.
- **Software:** Malware and tools used by adversaries.
- **Groups:** Known adversary groups that conduct attacks.

Beyond being a knowledge base, the **MITRE ATT&CK** framework offers a methodology that helps organizations assess and improve their security posture. This framework can be applied in various security processes, including threat modeling, vulnerability assessment, penetration testing, and red team exercises. Additionally, it serves as a benchmark for evaluating the effectiveness of security products and services.

Overview of the MITRE ATT CK Framework

Component	Description	Example
Tactic	The strategic approach used by the adversary to reach their target.	Initial Access
Technique	The specific method used to execute the tactic.	Phishing
Software	Malware or tool used by the adversary.	Mimikatz
Group	A known adversary group.	APT29

The **MITRE ATT&CK** framework is a cornerstone of modern cybersecurity strategies. It is a valuable resource for any organization looking to better understand threats, strengthen their defensive mechanisms, and become more resilient against cyberattacks. This framework is critical for keeping pace with the ever-evolving threat landscape and adopting a proactive security approach.

What is Threat Modeling?

Threat modeling is the process of identifying potential security vulnerabilities and threats against a system or application. This process helps us understand security risks proactively and take preventive measures. The **MITRE ATT&CK** framework serves as a valuable resource for understanding the tactics and techniques of cyber adversaries in threat modeling efforts. It focuses not just on technical analysis but also on business processes and potential impacts.

The threat modeling process is a critical step in strengthening an organization's security posture. Through this process, vulnerabilities are identified, and appropriate security measures can be applied to address these vulnerabilities. For example, during the threat modeling of a web application, common attack vectors like SQL injection and cross-site scripting (XSS) are evaluated, and protection mechanisms against such attacks are developed.

Steps of Threat Modeling

1. **Defining the System:** Provide a detailed description of the system or application you will model.
2. **Identifying Assets:** Identify critical assets that need protection (data, functionalities, etc.).
3. **Identifying Threats:** Determine possible threats against the assets (attack vectors, malicious actors, etc.).
4. **Analyzing Vulnerabilities:** Identify weaknesses and security gaps within the system.
5. **Assessing Risks:** Evaluate the potential impacts of the threats and vulnerabilities.
6. **Determining Mitigations:** Identify measures to reduce or eliminate risks.

7. **Validation and Monitoring:** Validate the effectiveness of the identified measures and continuously monitor the system.

Threat modeling should be an ongoing process and regularly updated. As new threats and vulnerabilities emerge, the threat model should adapt accordingly. This adaptation can be supported by following up-to-date information sources like **MITRE ATT&CK**. The results of threat modeling should also be shared among security teams, developers, and management to foster collaboration.

What is Threat Modeling?

Threat modeling is the process of identifying potential security vulnerabilities and threats against a system or application. This process helps us understand security risks proactively and take preventive measures. The **MITRE ATT&CK** framework serves as a valuable resource for understanding the tactics and techniques of cyber adversaries in threat modeling efforts. It focuses not just on technical analysis but also on business processes and potential impacts.

The threat modeling process is a critical step in strengthening an organization's security posture. Through this process, vulnerabilities are identified, and appropriate security measures can be applied to address these vulnerabilities. For example, during the threat modeling of a web application, common attack vectors like SQL injection and cross-site scripting (XSS) are evaluated, and protection mechanisms against such attacks are developed.

Steps of Threat Modeling

1. **Defining the System:** Provide a detailed description of the system or application you will model.
2. **Identifying Assets:** Identify critical assets that need protection (data, functionalities, etc.).
3. **Identifying Threats:** Determine possible threats against the assets (attack vectors, malicious actors, etc.).
4. **Analyzing Vulnerabilities:** Identify weaknesses and security gaps within the system.
5. **Assessing Risks:** Evaluate the potential impacts of the threats and vulnerabilities.
6. **Determining Mitigations:** Identify measures to reduce or eliminate risks.
7. **Validation and Monitoring:** Validate the effectiveness of the identified measures and continuously monitor the system.

Threat modeling should be an ongoing process and regularly updated. As new threats and vulnerabilities emerge, the threat model should adapt accordingly. This adaptation can be supported by following up-to-date information sources like **MITRE ATT&CK**. The results of threat modeling should also be shared among security teams, developers, and management to foster collaboration.

Threat Modeling Method	Description	Benefits
STRIDE	Analyzes threat categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.	Provides a comprehensive perspective, helps identify common threats.
DREAD	Evaluates risks based on Damage potential, Reproducibility, Exploitability, Affected users, Discoverability criteria.	Helps prioritize risks, ensures effective resource utilization.
PASTA	Process for Attack Simulation and Threat Analysis. Analyzes threats through attack simulations.	Helps understand threats from the attacker's perspective, creates realistic scenarios.
Attack Trees	Shows attack objectives and possible attack paths in a tree structure.	Offers a visual representation, simplifies understanding of complex attack scenarios.

Threat modeling is a critical process that helps organizations understand and manage cybersecurity risks. The effective use of the right methods and tools enhances this process and significantly strengthens the organization's security posture.

Methods Used in Threat Modeling

Method	Description	Advantages
STRIDE	Analyzes threats by categorizing them into six different groups.	Provides a comprehensive classification of threats, easily understandable.
DREAD	Used to evaluate the risk levels of threats.	Assists in prioritizing threats.
PASTA	An attacker-focused threat modeling approach.	Can be integrated into business processes, offers comprehensive analysis.
OCTAVE	A risk-based approach, identifying organizational risks.	Helps understand organizational risks, aligns with business processes.

Classifying Threats with MITRE ATT&CK

Tactic	Technique	Description
Reconnaissance	Active Scanning	The adversary performs network scanning to gather information about target systems.
Resource Development	Fake Accounts	The adversary creates fake social media accounts for social engineering or other purposes.
Initial Access	Phishing	The adversary convinces the victim to click on malicious links or share sensitive information.
Persistence	Startup Programs	The adversary sets up a program to maintain access even when the system is restarted.

Case Study: Famous Attacks

The **MITRE ATT&CK** framework is an invaluable resource for analyzing real-world attacks and improving defense strategies based on lessons learned from these attacks.

Attack Name	Targeted Sector	Key MITRE ATT&CK Tactics	Description
NotPetya	Diverse Sectors	Initial Access, Execution, Privilege Escalation, Lateral Movement, Impact	A destructive ransomware attack that started in Ukraine and spread globally.
SolarWinds	Technology, Government	Initial Access, Persistence, Privilege Escalation, Credential Access, Reconnaissance, Lateral Movement, Data Exfiltration	A complex supply chain attack executed through a vulnerability in the SolarWinds Orion platform.
WannaCry	Healthcare, Manufacturing	Initial Access, Execution, Propagation, Impact	A ransomware attack that rapidly spread by exploiting a vulnerability in the SMB protocol.
APT29 (Cozy Bear)	Diplomacy, Government	Initial Access, Persistence, Privilege Escalation, Credential Access, Reconnaissance, Lateral Movement, Data Exfiltration	A cyber espionage group aiming to access sensitive information using targeted phishing and specialized malware.

Real-World Breach Case Studies

1. Capital One Data Breach (2019)

Overview:

In July 2019, Capital One suffered one of the largest cloud-related data breaches in history. A former AWS employee exploited a Server-Side Request Forgery (SSRF) vulnerability in the company's Web Application Firewall (WAF), gaining unauthorized access to the AWS EC2 Instance Metadata Service. This allowed the attacker to obtain temporary IAM credentials and access sensitive customer data stored in Amazon S3 buckets.

Root Cause

- SSRF vulnerability in the web application.
- Misconfigured AWS Identity and Access Management (IAM) permissions.
- Excessive privileges assigned to cloud resources.

Impact

- Approximately 106 million customer records exposed.
- Personal information including names, addresses, credit scores, and Social Security Numbers compromised.
- Capital One faced regulatory fines, legal action, and reputational damage.

Security Controls That Could Have Prevented the Attack

- Implementation of AWS Instance Metadata Service Version 2 (IMDSv2).
- Least-privilege IAM policies.
- Regular cloud security posture assessments.
- Proper Web Application Firewall configuration.
- Continuous cloud security monitoring.

Key Lesson Learned

Cloud environments require proper configuration and continuous monitoring. Even secure cloud platforms can become vulnerable when misconfigured.

2. Equifax Data Breach (2017)

Overview:

In 2017, Equifax experienced one of the largest consumer data breaches after attackers exploited an unpatched Apache Struts vulnerability (CVE-2017-5638). The vulnerability had

already been publicly disclosed, but the organization failed to apply the available security patch.

Root Cause

- Failure to patch a known software vulnerability.
- Inadequate vulnerability management.
- Poor asset inventory and security governance.

Impact

- Personal information of approximately 147 million individuals exposed.
- Financial losses exceeding hundreds of millions of dollars.
- Significant legal penalties and reputational damage.

Security Controls That Could Have Prevented the Attack

- Timely patch management.
- Continuous vulnerability scanning.
- Automated asset management.
- Security configuration management.

Key Lesson Learned

Organizations must prioritize patch management because known vulnerabilities remain one of the easiest attack vectors for cybercriminals.

3. Target Data Breach (2013)

Overview:

Attackers compromised a third-party HVAC vendor and used stolen credentials to gain access to Target's internal network. Due to inadequate network segmentation, attackers moved laterally into the payment processing environment and installed malware on Point-of-Sale (POS) systems.

Root Cause

- Compromised third-party vendor credentials.
- Weak network segmentation.
- Insufficient monitoring of privileged access.

Impact

- Approximately 40 million payment card records stolen.
- Millions of customer records compromised.
- Significant financial losses and executive resignations.

Security Controls That Could Have Prevented the Attack

- Vendor risk management.
- Multi-Factor Authentication (MFA).
- Network segmentation.
- Continuous network monitoring.

Key Lesson Learned

Third-party vendors can become an organization's weakest security link and must be carefully managed.

4. SolarWinds Supply Chain Attack (2020)

Overview:

Attackers inserted malicious code into legitimate SolarWinds Orion software updates. Thousands of government agencies and private organizations unknowingly installed the compromised software, providing attackers with long-term access to internal networks.

Root Cause

- Compromise of the software development environment.
- Weak software supply chain security.
- Insufficient verification of software updates.

Impact

- More than 18,000 customers downloaded compromised updates.
- Multiple government agencies and Fortune 500 companies affected.
- Extensive cyber espionage campaign.

Security Controls That Could Have Prevented the Attack

- Secure Software Development Lifecycle (SSDLC).
- Code signing verification.
- Zero Trust architecture.

- Software integrity validation.

Key Lesson Learned

Software supply chains require the same level of security as production environments.

5. Colonial Pipeline Ransomware Attack (2021)

Overview:

The DarkSide ransomware group gained access using compromised VPN credentials that were not protected by Multi-Factor Authentication (MFA). The company shut down pipeline operations to contain the attack.

Root Cause

- Stolen VPN credentials.
- No Multi-Factor Authentication.
- Weak remote access security.

Impact

- Temporary shutdown of the largest fuel pipeline in the United States.
- Fuel shortages across several states.
- Millions of dollars paid in ransom and recovery costs.

Security Controls That Could Have Prevented the Attack

- Mandatory Multi-Factor Authentication.
- Strong password policies.
- Continuous VPN monitoring.
- Endpoint Detection and Response (EDR).

Key Lesson Learned

Remote access systems should always be protected using strong authentication mechanisms.

6. Uber Security Incident (2022)

Overview:

An attacker repeatedly sent MFA approval requests until an employee accepted one (MFA fatigue attack). The attacker then gained access to Uber's internal systems.

Root Cause

- Social engineering.
- MFA fatigue attack.
- Weak user awareness.

Impact

- Internal systems temporarily compromised.
- Source code and administrative tools accessed.
- Operational disruption.

Security Controls That Could Have Prevented the Attack

- Phishing-resistant MFA.
- Security awareness training.
- Privileged Access Management (PAM).
- Conditional access policies.

Key Lesson Learned

Human error remains one of the most effective attack vectors despite technical security controls.

7. Marriott (Starwood) Data Breach (2018)**Overview:**

Attackers maintained unauthorized access to Starwood's reservation systems for several years before being detected, exposing sensitive guest information.

Root Cause

- Long-term unauthorized access.
- Weak monitoring and detection.
- Inadequate encryption of sensitive data.

Impact

- Approximately 500 million guest records exposed.

- Regulatory penalties.
- Significant loss of customer trust.

Security Controls That Could Have Prevented the Attack

- Continuous threat hunting.
- Security Information and Event Management (SIEM).
- Encryption of sensitive information.
- Regular security audits.

Key Lesson Learned

Continuous monitoring is essential to reduce attacker dwell time within enterprise networks.

8. LastPass Security Incident (2022)

Overview:

Attackers compromised a developer's endpoint, obtained privileged access, and later accessed cloud storage containing encrypted customer password vault backups.

Root Cause

- Compromised developer credentials.
- Weak endpoint security.
- Insufficient protection of privileged accounts.

Impact

- Encrypted customer vault backups stolen.
- Loss of customer confidence.
- Increased security recommendations for users.

Security Controls That Could Have Prevented the Attack

- Hardware security keys.
- Endpoint Detection and Response.
- Privileged Access Management.
- Regular credential rotation.

Key Lesson Learned

Developer endpoints and privileged accounts require enhanced security controls.

9. MOVEit Transfer Breach (2023)

Overview:

Threat actors exploited a zero-day SQL Injection vulnerability in the MOVEit Transfer application, leading to widespread data theft across thousands of organizations.

Root Cause

- Zero-day SQL Injection vulnerability.
- Internet-facing application exposure.
- Delayed mitigation.

Impact

- Thousands of organizations affected worldwide.
- Large-scale theft of sensitive business and customer information.

Security Controls That Could Have Prevented the Attack

- Rapid vulnerability management.
- Web Application Firewall (WAF).
- Continuous application security monitoring.
- Virtual patching.

Key Lesson Learned

Organizations must continuously monitor internet-facing applications and respond rapidly to newly discovered vulnerabilities.

10. MGM Resorts Cyberattack (2023)

Overview:

Attackers used social engineering techniques to manipulate the IT help desk into resetting privileged account credentials, enabling ransomware deployment across enterprise systems.

Root Cause

- Help desk social engineering.
- Weak identity verification procedures.
- Privileged account compromise.

Impact

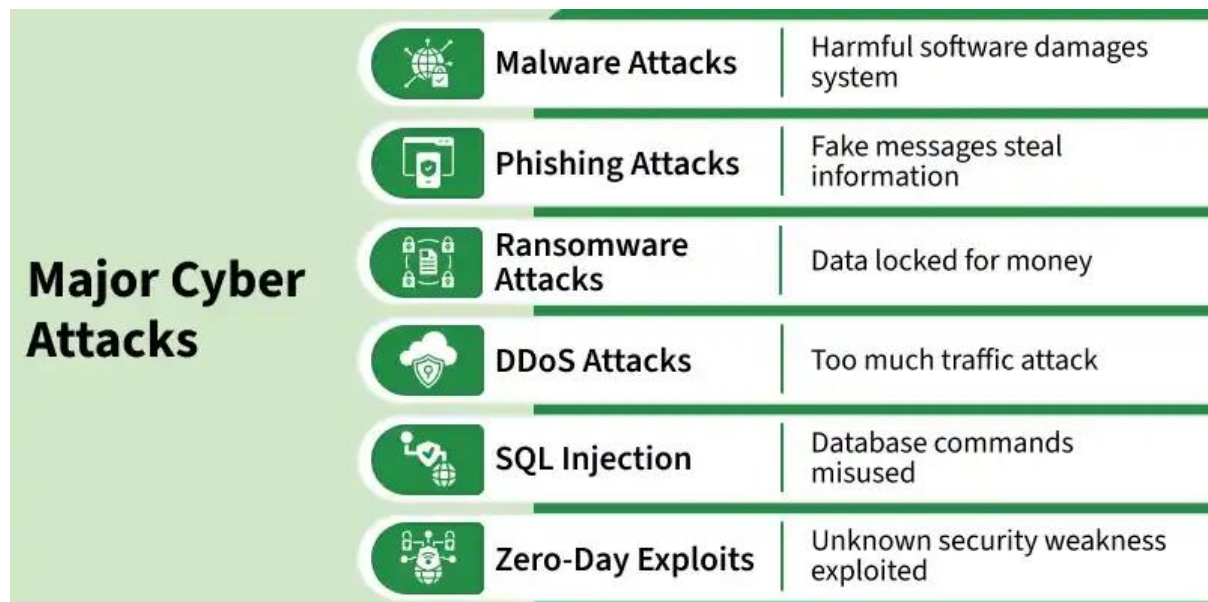
- Hotel operations disrupted.
- Reservation and casino systems affected.
- Financial losses exceeding \$100 million.

Security Controls That Could Have Prevented the Attack

- Strong identity verification procedures.
- Multi-Factor Authentication.
- Privileged Access Management.
- Employee security awareness training.

Key Lesson Learned

Help desk personnel should follow strict identity verification procedures before granting access or resetting credentials.



Attack Vectors and MITRE ATT&CK Mapping

What is an Attack Vector?

An **attack vector** is the path or technique an attacker uses to gain unauthorized access to a system, network, or application. Understanding attack vectors helps security professionals identify risks, implement effective defenses, and improve incident response.

1. Phishing

Description

Phishing is a social engineering attack where attackers send fraudulent emails, messages, or websites to trick users into revealing sensitive information or executing malicious files.

Common Objectives

- Steal usernames and passwords
- Deliver malware
- Gain initial access to a network

MITRE ATT&CK Mapping

Technique	ID	Description
Phishing: Spearphishing Attachment	T1566.001	Malicious email attachment
Phishing: Spearphishing Link	T1566.002	Malicious URL in email
Phishing via Service	T1566.003	Messages through trusted services

Prevention

- Email filtering
 - Multi-Factor Authentication (MFA)
 - Security awareness training
 - URL and attachment scanning
-

2. Malware

Description

Malware is malicious software designed to disrupt, damage, or gain unauthorized access to computer systems.

Examples

- Trojan
- Worm

- Spyware
- Rootkit

MITRE ATT&CK Mapping

Technique	ID	Description
User Execution	T1204	User runs malicious file
Command and Scripting Interpreter	T1059	Executes malicious commands
Ingress Tool Transfer	T1105	Downloads malware

Prevention

- Endpoint Detection and Response (EDR)
 - Antivirus software
 - Patch management
 - Application whitelisting
-

3. Ransomware

Description

Ransomware encrypts files or systems and demands payment to restore access.

Attack Lifecycle

1. Initial access
2. Lateral movement
3. Data encryption
4. Ransom demand

MITRE ATT&CK Mapping

Technique	ID	Description
Data Encrypted for Impact	T1486	Encrypts files
Inhibit System Recovery	T1490	Deletes backups
Lateral Tool Transfer	T1570	Spreads ransomware

Prevention

- Offline backups
 - Network segmentation
 - EDR
 - Regular patching
-

4. Insider Threat

Description

An insider threat originates from employees, contractors, or trusted users who intentionally or unintentionally compromise security.

Types

- Malicious insider
- Negligent insider
- Compromised insider account

MITRE ATT&CK Mapping

Technique	ID	Description
Valid Accounts	T1078	Uses legitimate credentials
Exfiltration Over Web Service	T1567	Steals sensitive data
Archive Collected Data	T1560	Compresses data before exfiltration

Prevention

- Least privilege
 - User Activity Monitoring
 - Privileged Access Management (PAM)
 - Data Loss Prevention (DLP)
-

5. Credential Attacks

Description

Credential attacks target usernames and passwords to gain unauthorized access.

Common Methods

- Brute Force
- Password Spraying
- Credential Stuffing

MITRE ATT&CK Mapping

Technique	ID	Description
Brute Force	T1110	Attempts multiple passwords
Password Spraying	T1110.003	Common password against many accounts
Credential Stuffing	T1110.004	Uses stolen credentials

Prevention

- Strong password policy
- MFA
- Account lockout
- Password manager

6. Social Engineering

Description

Social engineering manipulates people into revealing confidential information or performing actions that compromise security.

Examples

- Pretexting
- Baiting
- Tailgating
- Vishing
- Smishing

MITRE ATT&CK Mapping

Technique	ID	Description
Phishing	T1566	Deceptive communication

Technique	ID	Description
Trusted Relationship	T1199	Abuse of trusted relationships
Valid Accounts	T1078	Uses stolen credentials after social engineering

Prevention

- Cybersecurity awareness training
- Identity verification procedures
- MFA
- Email security solutions

Summary Table

Attack Vector	MITRE ATT&CK Technique	Technique ID
Phishing	Spearphishing Attachment	T1566.001
Malware	User Execution	T1204
Malware	Command and Scripting Interpreter	T1059
Ransomware	Data Encrypted for Impact	T1486
Ransomware	Inhibit System Recovery	T1490
Insider Threat	Valid Accounts	T1078
Insider Threat	Exfiltration Over Web Service	T1567
Credential Attacks	Brute Force	T1110
Credential Attacks	Password Spraying	T1110.003
Social Engineering	Phishing	T1566
Social Engineering	Trusted Relationship	T1199

1. Executive Summary

Cybersecurity has become one of the most critical business priorities in 2026. Rapid adoption of cloud computing, artificial intelligence, remote work, and digital services has expanded the attack surface available to cybercriminals. Modern attackers increasingly use AI to automate phishing, create convincing deepfakes, steal identities, and accelerate malware development, while defenders are also adopting AI to improve detection and response capabilities.

The purpose of this report is to increase cybersecurity awareness by explaining today's threat landscape, common attack techniques, practical security controls, and lessons learned from major cyber incidents. It emphasizes that cybersecurity is a shared responsibility involving technology, processes, and people.

2. Introduction

What is Cybersecurity?

Cybersecurity is the practice of protecting computers, networks, applications, cloud environments, and digital information from unauthorized access, cyberattacks, theft, and disruption.

Objectives

- Protect Confidentiality
 - Maintain Integrity
 - Ensure Availability
 - Reduce Cyber Risk
 - Improve Organizational Resilience
-

3. Cyber Threat Landscape in 2026

Major trends include:

- AI-powered phishing campaigns
- Deepfake impersonation attacks
- Identity-based attacks
- Ransomware and data extortion
- Supply chain compromises

- Cloud misconfigurations
- Insider threats
- Internet of Things (IoT) attacks
- Critical infrastructure targeting

AI-related vulnerabilities and misuse of generative AI tools are among the fastest-growing risks, while geopolitical tensions and supply-chain dependencies continue to influence cyber threats.

4. Common Cyber Threats

Phishing

Attackers send fraudulent emails or messages to steal credentials or deliver malware.

Types

- Email phishing
- Spear phishing
- Whaling
- Smishing
- Vishing
- QR phishing (Quishing)

Prevention

- Verify sender identity
 - Avoid suspicious links
 - Report phishing emails
 - Enable MFA
-

Ransomware

Malware encrypts files and demands payment for decryption.

Common Infection Methods

- Phishing emails
- Remote Desktop attacks

- Unpatched vulnerabilities
- Stolen credentials

Organizations continue to report ransomware as one of the highest-impact threats, with phishing and identity attacks remaining common entry points.

Malware

Types

- Trojan
 - Worm
 - Virus
 - Spyware
 - Rootkit
 - Keylogger
-

Insider Threats

Types

- Malicious Insider
 - Negligent Employee
 - Compromised Account
-

Credential Theft

Attack Methods

- Password Spraying
 - Credential Stuffing
 - Brute Force
 - MFA Fatigue
 - Session Cookie Theft
-

5. Cyber Hygiene Best Practices

- Enable Multi-Factor Authentication (MFA)
 - Use strong, unique passwords
 - Install security updates promptly
 - Keep software and operating systems current
 - Back up important data regularly
 - Lock devices when unattended
 - Avoid downloading software from untrusted sources
 - Encrypt sensitive information
 - Use antivirus and endpoint protection
-

6. Social Engineering Awareness

Attackers manipulate human psychology rather than exploiting software vulnerabilities.

Common Techniques

- Phishing
- Pretexting
- Baiting
- Tailgating
- Quid Pro Quo
- Deepfake Voice Calls

Red Flags

- Urgent requests
 - Requests for passwords
 - Unexpected attachments
 - Financial requests
 - Unknown QR codes
-

7. AI and Cybersecurity

Artificial Intelligence now plays a major role in both cyber defense and cybercrime.

Defensive Applications

- Threat Detection
- Malware Analysis
- User Behavior Analytics
- Automated Incident Response
- Security Operations Center Automation

Criminal Use

- AI-generated phishing
- Deepfake videos
- Voice cloning
- Automated malware
- Synthetic identities

Security awareness programs are increasingly being redesigned to address risks associated with generative AI and unauthorized use of AI tools.

8. Cloud Security Awareness

Common Cloud Risks

- Misconfigured Storage
- Weak IAM Policies
- Exposed APIs
- Public Buckets
- Insecure Secrets Management

Best Practices

- Principle of Least Privilege
- Encryption
- Continuous Monitoring
- Cloud Security Posture Management

- IAM Reviews
-

9. Password and Identity Security

Recommendations

- Password managers
 - Long passphrases
 - MFA
 - Biometrics where appropriate
 - Password rotation only when necessary
 - Monitor for compromised credentials
-

10. Mobile & Remote Work Security

Recommendations

- Secure Wi-Fi
 - VPN where required
 - Device encryption
 - Screen lock
 - Secure BYOD policies
 - Keep mobile OS updated
-

11. Safe Internet Practices

Users should:

- Verify website URLs
- Use HTTPS
- Avoid pirated software
- Download only from trusted sources
- Avoid unknown USB devices
- Review application permissions

12. Incident Response

If a security incident occurs:

1. Disconnect the affected device if appropriate.
2. Report the incident immediately.
3. Preserve evidence.
4. Do not delete suspicious files.
5. Change compromised passwords.
6. Follow organizational incident response procedures.